

## Email

### Balida, Nickolai

---

**From:** Balida, Nickolai

**Sent:** Monday, 22 September 2025, 10:44 AM

**To:** Thrift, Mark

**Subject:** Penetration Testing Results

Dear Mr. Thrift,

As part of the recent penetration testing engagement, our team has identified two critical vulnerabilities across different scenarios. Below is a summary of the findings, associated risk levels, reproduction steps, and recommended mitigation strategies aligned with industry standards (OWASP, NIST) and DataTrust workplace policies.

**1. SQL Injection Vulnerability: Web Application Login Page**

- **Risk Level:** Critical
- **Actions:** Using the web application's login input field, we tested with an SQL statement ('OR '1'='1) which bypassed authentication controls and returned unauthorised access to the database. This confirmed that the application does not properly validate or sanitise user inputs.
- **Recommended Mitigations:**
  1. Implement input validation and sanitization in line with OWASP guidelines to prevent direct execution of user input.
  2. Apply web application firewall rules to detect and block suspicious queries in real time.

**2. Exposed FTP Service: Outdated vsFTPd 2.3.4**

- **Risk Level:** High
- **Actions:** Port scanning tools revealed that port 21 (FTP) was open and running vsFTPd 2.3.4. Analysis indicates this version contains a backdoor vulnerability (CVE-2011-2523) that could be exploited for unauthorised remote access.
- **Recommended Mitigations:**
  1. Immediately decommission or patch outdated FTP services in accordance with NIST patch management standards.
  2. Replace FTP with secure alternatives such as SFTP or FTPS, as outlined in the DataTrust Server Security Policy.

These vulnerabilities present the most significant risk to the organization's data confidentiality, integrity and availability. Implementing the above mitigation strategies will fortify the security posture at DataTrust and reduce exposure to external threats.

If you have any questions, please let me know, and I will be presenting a more technical breakdown and demonstrating the findings tomorrow.

Kind regards,

Nickolai Balida

**Cybersecurity Analyst - DataTrust**

